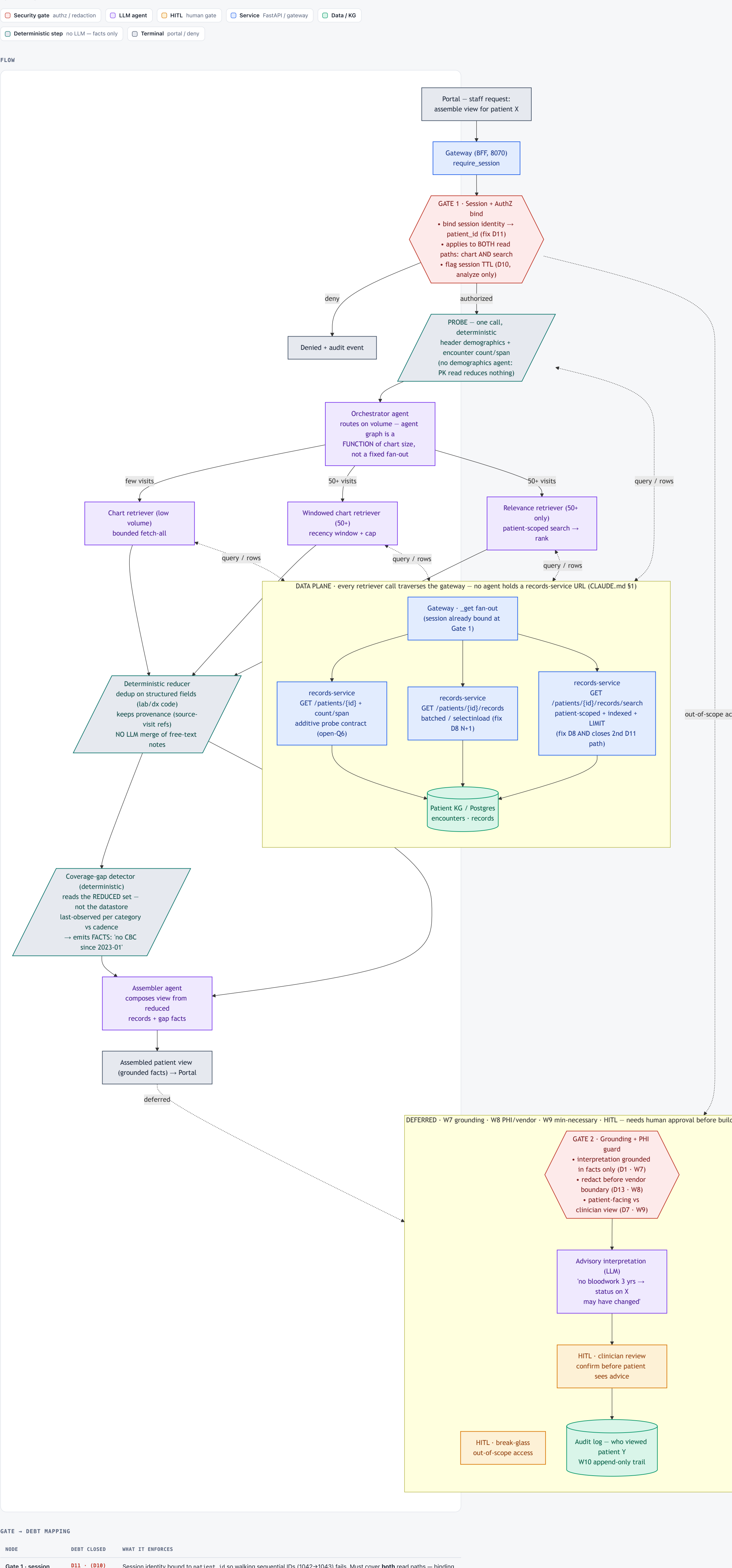


Multi-Agent Patient-View Assembly

Proposed orchestration for the W4 ask — “assemble patient view.” The agents earn the fan-out by **routing and reducing**, not by fetching in parallel: one probe call decides the shape, and the **agent graph differs by volume** (a 2-visit chart spawns fewer agents than a 60-visit one). Wrapped by the security gate W4 exists to fix — IDOR on `/patients/{id}/records`, plus the second cross-patient path through `/records/search` — and the N+1 chart read. Clinical interpretation of gaps sits behind a **deferred W7/W8/W9 boundary**, not built here. **The fan-out is not the latency fix**; bounded, indexed, batched reads are (see notes).

D11 IDOR · 2 read paths · D8 N+1 / full-scan · D18 session TTL · D7 minimum-necessary · sketch — W3 PR #14 still pending · rev. 2026-07-27



GATE → DEBT HAPPING

NODE	DEBT CLOSED	WHAT IT ENFORCES
Gate 1 - session bind	D11 · (D10)	Session identity bound to <code>patient_id</code> so walking sequential IDs (1042→1043) fails. Must cover both read paths — binding only the chart endpoint leaves the unscoped search path open. Session TTL (D10) analyzed/flagged only — not shipped this week. (D7 min-necessary moved to the deferred boundary → W9.)
Probe - one call	D8	Header demographics + encounter count/span in a single call, so routing can happen before any chart read. Replaces the old standalone demographics-retriever agent: <code>GET /patients/{id}</code> is a primary-key read that reduces nothing, so wrapping it in an agent was exactly the parallel-GET fan-out open-Q2 rejected. Needs an additive contract change (open-Q6).
Orchestrator - volume-aware routing	D8	Routes on the probe result: few visits → one bounded chart retriever, no search agent at all ; 50+ → windowed retriever + scoped relevance retriever for rank/cap. The agent count varies with chart size — an identical graph for a 2-visit and a 60-visit patient would mean no routing was demonstrated. This is the agentic work the reviewer flagged as missing.
Scoped search path	D11 · D8	Today <code>GET /records/search</code> runs an unbounded, unindexed ILIKE across every patient's records — a second D11 read path Gate 1's <code>patient_id</code> bind does not cover, not just a perf issue. <code>records.patient_id</code> already exists, so the scope predicate is available; index + LIMIT are the DB half. Needs an adversarial test proving a scoped search cannot return another patient's record.
Reducer - dedup w/ provenance	D8	Dedups records repeated across visits, keeping source-visit refs. Deterministic on structured fields (lab code, dx code) — not an LLM merge of free-text notes. Everything downstream (assembler and gap detector) consumes the reduced set; nothing reaches Postgres without passing Gate 1 and the volume bound, or the bound and the dedup are decorative.
Data plane - gateway-only	S1 invariant	No retriever holds a records-service URL — every call goes portal → gateway → service. Where the agents themselves run (ai-assistant 8077 vs. gateway-side) is still open and is auth-boundary-adjacent: 8077 is the only vendor-egress path, and the gateway is a load-bearing wall (open-Q5).
Coverage-gap detector (in scope)	facts	Deterministic: last-observed per category vs. expected cadence → emits facts (no CBC since 2023-01). No clinical interpretation — that's the line into the deferred boundary.
Gate 2 - grounding + PHI	D1 · D13 · D7	Interpreting a gap fact into patient advice must be grounded in facts (D1/W7), redacted before any vendor boundary (D13/W8), and scoped patient-vs-clinician (D7/W9). Out of W4.
HITL nodes (deferred)	approval	Break-glass on out-of-scope access; clinician confirmation before a patient sees interpreted advice. Not in any current spec — future question, human approval before build.
Audit log (deferred)	D2 · D12	Every finalized view writes an access event → answers "who viewed patient Y?" (feeds W10 append-only trail).

WHERE THE SPEED ACTUALLY COMES FROM

The client ask says "make it feel fast." The fan-out does not do that — it adds hops. The latency win is entirely in bounded reads, and the writeup must attribute it that way with before/after query counts: batched encounter→record loading instead of 1+N (records-service/app.py:112 runs one query per encounter, deliberately); a `patient_id`-scoped, indexed search with a LIMIT instead of a full-table ILIKE (app.py:132); and a recency window + cap on high-volume charts. The agents earn their keep by deciding what not to fetch. Presenting parallelism as the performance story invites the obvious rebuttal — three agents on one service and one database is more work, not less.

NOTES

Rev. 2026-07-27 — three corrections against the previous sketch, all found by reading `records-service/app.py`: (a) the demographics retriever was a bare PK read doing no reduction, so it collapsed into the orchestrator's probe — one call, not three; (b) the search agent called `/records/search`, which has no `patient_id` predicate, so a "patient view" was reading across all patients behind the authz gate — now scoped and bounded; (c) the raw service responses flowed straight to the assembler and the gap detector read the datastore directly, both bypassing the dedup and the volume bound — everything downstream now consumes the reduced set. Reviewer past (2026-07-24) had already reshaped this from three parallel GETs into agents that route and reduce.

Open questions before it becomes an ADR (tracks docs/specs/W4.md §7.1): (1) does "session bind" mean patient-ownership or a care-relationship check — Riverbend has no such table yet; (2) is the fan-out worth it vs. one retriever — resolved: justified only by routing + reduction, else collapse to a single retriever; (3) semantic dedup of free-text notes can collapse clinically-distinct findings — prototype dedups structured fields only, with provenance, needs an adversarial test before any LLM merge; (4) HITL gates add latency — confirm which are mandatory vs. break-glass only; (5) where do the agents run — ai-assistant (8077, but that is the only vendor-egress path) vs. gateway-side (shorter hops, but the gateway is a load-bearing wall that owns auth); (6) does the probe need a new endpoint — no endpoint returns count/span today, and getting the count by fetching the whole chart defeats the probe. Additive only either way. IDOR/N+1 fixes touch the auth boundary → human approval required per CLAUDE.md §8 before any code lands. "Full picture in one view" is scoped to the viewer: full-for-a-clinician ≠ full-for-a-patient (D7 → W9).